Semana 03 — Marco legal, ético y normativo

Fase 1: Fundamentos, criptografía y marco legal — instrucciones paso a paso

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	03 de 10
Fase	1 — Fundamentos, criptografía y marco legal
Modalidad	4 grupos, trabajo desde sus propios equipos
Dedicación	4 horas de laboratorio + 2 horas de estudio independiente
Instrumento	Control de fase 1
Entrega	GitHub, carpeta semana_03/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Antes de la sesión

Estas tareas se hacen en casa, antes de la práctica. Si el repositorio o el laboratorio no están listos al empezar, la sesión se va en arreglarlos y no alcanza para el informe.

1. Comprobar que el repositorio del grupo tiene la carpeta semana_03 creada.
2. Revisar la retroalimentación del docente sobre la semana anterior y corregir lo pendiente.
3. Traer instaladas las herramientas de la semana: Plantilla de autorización, Normativa en PDF.
4. Confirmar que el laboratorio arranca y que los tres servicios responden antes de la sesión.
5. Leer el objetivo y los contenidos para llegar con el vocabulario de la práctica.

2 Objetivo de la semana

Identificar las obligaciones legales y normativas antes de auditar, y redactar un alcance autorizado con reglas de enfrentamiento.

3 Contenidos que se aplican

- Ley Especial contra los Delitos Informáticos y tipos penales aplicables.
- Autorización escrita, alcance, ventana de pruebas y reglas de enfrentamiento.
- ISO IEC 27001, NIST CSF 2.0, ENS y GDPR como marcos de referencia.
- OWASP ASVS y WSTG como estándares de verificación técnica.
- Cadena de custodia, integridad de la evidencia y confidencialidad.
- Código de ética del curso y consecuencias del uso indebido.

4 Escenario

Cada grupo redacta la autorización de la auditoría de su objetivo del laboratorio y analiza un incidente ficticio, identificando qué normas se violaron y qué evidencia sería admisible.

5 Paso a paso de la práctica

1. Redactar el alcance con activos incluidos, activos excluidos y ventana de pruebas.
2. Añadir reglas de enfrentamiento para hallazgos críticos y para datos personales.
3. Analizar el caso ficticio y tipificar las conductas descritas.
4. Determinar qué evidencia es admisible y cuál se contaminó en el relato.
5. Firmar el código de ética del curso de forma individual.

Concepto clave

Regla de oro de la evidencia: guarda la salida de cada paso en `semana_03/evidencia/` en el momento en que la obtienes. Reconstruirla después no es evidencia, es memoria.

Herramientas de la semana: Plantilla de autorización, Normativa en PDF.

6 Rol de cada grupo esta semana

Todos los grupos resuelven la misma práctica, cada uno en su propio repositorio y su propio laboratorio: el trabajo de un grupo no depende del de otro. El rol cambia el énfasis del trabajo y lo que cada grupo aporta al comparar resultados en clase, al final.

Grupo	Rol	Aporte principal
Grupo 1	**Rojo**	Evidencia cruda en semana_03/evidencia y el apartado de reproducción del informe.
Grupo 2	**Azul**	La mitigación aplicada, el comando de verificación y la comparación de resultados.
Grupo 3	**Púrpura**	La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.
Grupo 4	**Legal y reporte**	La versión final del informe y la declaración explícita de lo que no se pudo verificar.

7 Qué se entrega

Autorización firmada, análisis del caso y código de ética firmado por cada estudiante.

Estructura de la carpeta `semana_03/`:

- README.md con integrantes, roles y tabla de semanas entregadas.
- semana_03/informe.md o informe.pdf con el entregable de esa práctica.
- semana_03/scripts/ con el código, con type hints y docstrings.
- semana_03/evidencia/ con salidas, capturas y hashes anonimizados.
- semana_03/README.md con el resumen de lo hecho y lo que no se pudo verificar.

Reglas que se verifican al corregir:

- Nada de secretos, tokens ni contraseñas en el repositorio; las claves van en .env ignorado.
- Nada de imágenes de disco, muestras de malware ni binarios: solo hashes y enlaces.
- Evidencia anonimizada: sin datos personales de terceros ni credenciales reales.
- Un commit por entrega con mensaje "semana NN: <entregable>".
- La práctica cuenta como entregada solo si está en el repositorio antes del corte.

8 Cómo se corrige

Criterio	Peso
Alcance explícito con inclusiones y exclusiones	3,0
Reglas de enfrentamiento operativas	2,5
Tipificación correcta de las conductas del caso	2,0
Juicio fundamentado sobre admisibilidad de la evidencia	1,5
Código de ética firmado individualmente	1,0
Total	**10,0**

9 Lista de verificación antes del corte

- El repositorio del grupo existe, es privado y el docente aparece como colaborador.
- La carpeta semana_03/ está en el repositorio, no solo en el equipo.
- El informe explica qué se hizo, con qué comandos y qué se obtuvo.
- La evidencia está anonimizada: sin datos personales, credenciales ni secretos.
- Cada hallazgo tiene su hash o su salida cruda que permite reproducirlo.
- El commit ’semana 03: <entregable>’ está hecho antes del corte.

Alcance y autorización: solo se trabaja sobre los contenedores del laboratorio o sobre sistemas con autorización escrita. Si el objetivo no está en ese conjunto, se detiene la práctica y se consulta al docente. El uso de estas técnicas fuera del alcance tiene consecuencias académicas y legales.

Recuerda

Dudas de la semana: se responden en clase o en el repositorio. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

10 Glosario de la semana

Término	Definición
Autorización escrita	Permiso firmado que delimita qué se puede probar, desde dónde y en qué ventana de tiempo. Sin ella no hay prueba técnica legítima.
Reglas de enfrentamiento	Condiciones operativas de la prueba: alcance, ventana, sistemas excluidos, contacto y criterios de parada. Se acuerdan antes de empezar.
ISO/IEC 27001	Norma de sistemas de gestión de seguridad de la información. Exige política, análisis de riesgos, controles y mejora continua.
NIST CSF	Marco voluntario con las funciones identificar, proteger, detectar, responder y recuperar. Ordena el programa de seguridad sin prescribir productos.
OWASP ASVS	Estándar de verificación de seguridad de aplicaciones con requisitos por nivel. Se usa como lista de comprobación técnica.
Cadena de custodia	Registro que documenta quién tuvo la evidencia, cuándo, dónde y con qué integridad. Una rotura de la cadena le quita valor probatorio.
Código de ética	Reglas de conducta del curso: solo objetivos autorizados, evidencia anonimizada, sin daño y con divulgación responsable.